POUR ALLER PLUS LOIN

- Afin d'assurer le suivi de la sécurité et de la protection des données au quotidien, il est très utile (voire obligatoire selon la nature de l'organisme) de **nommer une personne responsable de la sécurité des systèmes d'information (RSSI) et un délégué à la protection des données**[7] **(DPD)**. Ils doivent :
  - avoir la capacité de **rapporter directement au niveau le plus élevé de la direction** ;
  - **disposer des ressources nécessaires et des conditions de travail** pour exercer leurs missions ;
  - **être impliqués** (eux-mêmes ou leur équipe) systématiquement et en amont dans les réflexions sur les questions relatives à leur champ de compétences afin d'assurer une sécurité des systèmes d'information et la protection des données personnelles **dès la conception et par défaut**.
- Les objectifs généraux en matière de protection des données personnelles peuvent être consignés dans une politique générale de protection des données, portée par la direction et diffusée à l'ensemble des acteurs (personnels, sous-traitants, partenaires). Cette politique peut ensuite être précisée à un niveau opérationnel en politiques thématiques et procédures détaillées pour décliner au contexte d'activité de l'organisme les mesures de protection des données personnelles.
- **Les audits de sécurité sont un moyen essentiel pour évaluer le niveau de sécurité des systèmes sur lesquels reposent le(s) traitement(s) de données personnelles.** Réalisés de façon périodique, ils permettent de prendre en compte les évolutions du traitement et des menaces. Chaque audit doit donner lieu à un plan d'action dont la mise en œuvre devrait être suivie au plus haut niveau de l'organisme.
- Afin de structurer la gouvernance dans la durée, il est possible de mettre en place un système de management reposant sur une démarche d'amélioration continue. La norme internationale ISO/IEC 27701[8] décrit les processus et les mesures organisationnelles et techniques permettant de mettre en place un système de management de la protection de la vie privée (PIMS, en anglais), en s'appuyant sur le système de management de la sécurité de l'information (SMSI) porté par la norme ISO/IEC 27001.
- L'Agence nationale de la sécurité des systèmes d'information (ANSSI) a publié son propre guide[9] des bonnes pratiques en termes de sécurité informatique.

7 « Devenir délégué à la protection des données », cnil.fr

8 « L'ISO 27701, une norme internationale pour la protection des données personnelles », cnil.fr

9 « Guide d'hygiène informatique », cyber.gouv.fr